ĐỀ TÀI BÀI TẬP LỚN

Môn học *"Nguyên lý các tiêu chuẩn đánh giá an toàn thông tin"*

HƯỚNG DẪN CHUNG

Môn học này không nhằm bắt học thuộc lòng các văn bản pháp lý khô khan mà là giúp hình thành **Tư duy cốt lõi của một chuyên gia thiết kế và đánh giá hệ thống**, biết dùng tiêu chuẩn làm công cụ để giải quyết các bài toán bảo mật thực tế. Để hoàn thành tốt đề tài trong vòng 1.5 tháng, cần nắm vững hai nguyên tắc cốt lõi sau:

1. Bản chất cốt lõi: Tính liên kết xuyên suốt của chu trình PDCA

Cả đề tài về quản lý (ISO 27001) hay kỹ thuật mạng (TCVN 11930), quyển báo cáo của nhóm bắt buộc phải tuân theo một logic vòng lặp không được đứt gãy. Giảng viên sẽ chấm điểm dựa trên **Tính liên kết** chứ không chấm dựa trên độ dày của báo cáo:

- **PLAN (Lập kế hoạch):** Chỉ ra hệ thống có tài sản gì và đang đối mặt với những nguy cơ/rủi ro cụ thể nào?
- **DO (Triển khai mẫu):** Văn bản quy định hoặc sơ đồ giải pháp nhóm thiết kế ra ở khâu này **phải sinh ra để giải quyết đúng các rủi ro** đã chỉ ra ở khâu PLAN. (Ví dụ: PLAN nói rủi ro là lộ mật khẩu, thì DO phải có quy định đặt mật khẩu mạnh và đổi mật khẩu định kỳ).
- **CHECK (Hậu kiểm):** Bảng checklist đánh giá nội bộ của nhóm phải đi kiểm tra xem người ta có tuân thủ đúng những gì đã viết ở khâu DO hay không. Tình huống lỗi giả định phát hiện ra phải thực tế.
- **ACT (Cải tiến):** Giải pháp nhóm đề xuất ở khâu này phải là phương án kỹ thuật hoặc cơ chế tự động để **sửa triệt để tận gốc cái lỗi** vừa tìm thấy ở khâu CHECK, không để nó lặp lại trong tương lai.

Lời khuyên: Nếu các phần PLAN - DO - CHECK - ACT của nhóm không "nói chuyện" với nhau, bài tập lớn của nhóm sẽ bị đánh giá là copy-paste và không đạt yêu cầu.

2. Gợi ý 4 mẹo làm việc nhóm hiệu quả

Mẹo 1: Phân vai rõ ràng theo năng lực (Đừng làm chung một lúc)

Một nhóm nên chia vai như một đội ngũ đi làm dự án thật:

- **01 Trưởng nhóm (Lead Consultant):** Quản lý tiến độ, chịu trách nhiệm chính về tính logic xuyên suốt của chu trình PDCA, kết nối nội dung giữa các khâu.
- **Thành viên thế mạnh Quy trình/Chính sách:** Tập trung nghiên cứu sâu văn bản tiêu chuẩn, chịu trách nhiệm viết văn bản, nội quy, cẩm nang ứng xử (Khâu PLAN, DO, văn bản quy chế).
- **Thành viên thế mạnh Kỹ thuật/Trực quan:** Chịu trách nhiệm vẽ sơ đồ kiến trúc, thực hiện các ảnh chụp cấu hình mẫu hệ điều hành (Hardening/Baseline) và thiết kế sản phẩm truyền thông (Poster/Infographic) bằng Canva/Visio.

Mẹo 2: Thực tế hóa giải pháp (Nói KHÔNG với giải pháp vĩ mô)

Nhóm đang giải quyết bài toán cho một Startup 20 người, một phòng Lab trường học, hoặc một quán cà phê dịch vụ.

- **Tuyệt đối không** đưa các giải pháp quá đắt đỏ hoặc phức tạp của tập đoàn nghìn người vào bài làm (ví dụ: bắt quán cà phê mua thiết bị tường lửa hàng trăm triệu, bắt startup mua phần mềm quản lý bản quyền đắt đỏ).
- Hãy ưu tiên tối đa các giải pháp có sẵn của hệ điều hành (BitLocker, Group Policy, Local Account), các công cụ mã nguồn mở, phần mềm miễn phí hoặc các thay đổi về mặt quy trình con người. **Giải pháp thông minh là giải pháp hiệu quả với chi phí tối ưu nhất.**

Mẹo 3: Quy tắc "Bình dân hóa" ngôn ngữ

Khi viết văn bản chính sách ở khâu DO (như nội quy phòng máy, cẩm nang cho dân văn phòng), hãy nhớ đối tượng đọc là những người không biết sâu về kỹ thuật.

- Hãy dùng từ ngữ phổ thông, ngắn gọn, chỉ rõ hành động **NÊN** và **KHÔNG NÊN**. Thay vì viết: *"Yêu cầu cấu hình mật mã hóa bất đối xứng để xác thực"*, hãy viết: *"Tuyệt đối không nhấn vào các đường link lạ trong email và không chia sẻ mật khẩu Wi-Fi nội bộ cho khách hàng"*.

Mẹo 4: Quản lý tiến độ theo tuần (Quy tắc "cuốn chiếu")

Đừng đợi đến tuần cuối cùng mới ngồi chắp vá báo cáo, chắc chắn không kịp! Hãy làm cuốn chiếu: Tuần 1-2 chốt xong toàn bộ phần PLAN. Tuần 3 làm xong phần DO. Tuần 4, 5 hoàn thiện nốt CHECK - ACT. Trong quá trình làm có thể nhờ giảng viên góp ý trên lớp.

3. Cách chấm điểm

Bên cạnh bài nộp (được mô tả cụ thể ở từng đề tài), các nhóm sẽ phải chuẩn bị presentation kết quả làm việc và có buổi trình bày, trả lời vấn đáp trong khoảng 20-25’ tại buổi học cuối cùng của môn. Presentation cần nêu rõ:

- Bảng công việc thực tế: Ai làm gì?
- Phân tích bài toán
- Các bảng, hình ảnh, biểu đồ thể hiện kết quả của quá trình làm việc.

Điểm sẽ bao gồm 2 thành phần:

- Điểm của nhóm (A): Đánh giá mức độ hoàn thành của cả nhóm đối với các yêu cầu của từng đề tài – căn cứ bản mềm các tài liệu đầu ra (cần nộp trước 1 tuần) và nội dung trình bày.
- Điểm cá nhân (B): Đánh giá mức độ tham gia xây dựng bài tập lớn, trình bày, nắm bắt, trả lời câu hỏi của từng cá nhân tại buổi trình bày.
- Điểm cuối cùng: C = A*60% + B*40%
- Ví dụ: Điểm chung của nhóm đạt 9 (xử lý thành công 90% yêu cầu đề tài), trong nhóm bạn X, Y lần lượt được điểm cá nhân là 8 và 6 thì điểm cuối cùng của mỗi bạn là:
    - X: 9*0.6 + 8*0.4 = 8.6
    - Y: 9*0.6 + 6*0.4 = 7.8

Chúc các nhóm làm việc hiệu quả và có một trải nghiệm "làm nghề" thực tế thú vị!

Đề tài 1: Áp dụng chu trình PDCA theo TCVN ISO/IEC 27001:2019 để xây dựng và cải tiến Hệ thống an toàn thông tin cho một Startup công nghệ

1. Bối cảnh bài toán

Một công ty khởi nghiệp (Startup) chuyên phát triển ứng dụng di động có **20 nhân sự** bao gồm: 1 Giám đốc (CEO), 1 Giám đốc công nghệ (CTO), 12 Lập trình viên (Developers), 3 Nhân viên Kiểm thử (Tester), 2 Nhân viên Kinh doanh (Sales) và 1 Kế toán.

Công ty làm việc tại một văn phòng không gian mở (Co-working space), chưa có phòng máy chủ riêng (mọi thứ dùng Cloud và GitHub). Để tiết kiệm chi phí, công ty áp dụng chính sách **BYOD (Bring Your Own Device)** – nhân viên tự mang laptop cá nhân (Windows hoặc macOS) đến văn phòng để làm việc và kết nối vào mạng Wi-Fi chung của tòa nhà. Hiện tại, công ty chưa có bất kỳ quy định, chính sách hay biện pháp kiểm soát an toàn thông tin nào.

2. Nhiệm vụ của nhóm (Cấu trúc theo chu trình PDCA)

Nhóm đóng vai một **Đội tư vấn ATTT độc lập** được CEO thuê về để thiết lập hệ thống quản lý an toàn thông tin cho công ty từ con số 0 trong vòng 1.5 tháng. Nội dung nghiên cứu và triển khai trong báo cáo bắt buộc phải đi qua 4 khâu:

KHÂU 1: PLAN (Lập kế hoạch & Thiết kế hệ thống) - *Chiếm 60% tổng số điểm*

- **Đầu mục 1.1: Asset Inventory:** Lập bảng danh mục tối thiểu 08 tài sản thông tin quan trọng nhất (Phần cứng, phần mềm, dữ liệu, con người). Xác định rõ chủ sở hữu (Asset Owner) và mức độ quan trọng (Cấp độ: Cao/Trung bình/Thấp).
- **Đầu mục 1.2: Risk Register (Đánh giá rủi ro):** Xác định và phân tích ít nhất **08 nguy cơ** mất an toàn thực tế đối với bối cảnh trên (Phải bao gồm cả nguy cơ về kỹ thuật, con người và vật lý văn phòng mở). Đánh giá định tính rủi ro dựa trên Xác suất (Likelihood) và Tác động (Impact).
- **Đầu mục 1.3: Statement of Applicability (SoA) & Risk Treatment Plan (RTP):**
    - Đối chiếu Phụ lục A của ISO 27001 để lựa chọn các biện pháp kiểm soát phù hợp nhằm giảm thiểu 08 rủi ro đã chỉ ra (Đặc biệt lưu ý các điều khoản về BYOD, Quản lý tài sản, An toàn nguồn nhân lực).
    - Viết kế hoạch xử lý rủi ro (RTP) cụ thể: *Ai làm? Dùng công cụ gì? Thời hạn bao lâu? Chi phí ước tính?*

KHÂU 2: DO (Triển khai & Truyền thông mẫu) - *Chiếm 20% tổng số điểm*

Vì không có môi trường thật để cài đặt cấu hình trực tiếp lên hạ tầng của doanh nghiệp, nhóm phải tạo ra các sản phẩm thể hiện năng lực thực thi quy trình:

- **Đầu mục 2.1: Dự thảo Văn bản Chính sách (Policy):** Viết một bản quy định ngắn gọn, ngôn từ rõ ràng dài khoảng 2-3 trang về *"Quy định bảo mật đối với thiết bị cá nhân (BYOD) và làm việc tại không gian mở"*.
- **Đầu mục 2.2: Demo Kỹ thuật Baseline:** Chụp ảnh minh họa các bước hướng dẫn nhân viên tự cấu hình bảo mật trên máy tính của họ (Ví dụ: Cách bật mã hóa ổ cứng BitLocker/FileVault, cách cấu hình tự động khóa màn hình sau 5 phút không hoạt động để đáp ứng chính sách đã viết).

- **Đầu mục 2.3: Sản phẩm nhận thức (Awareness):** Thiết kế 01 Infographic hoặc Poster truyền thông trực quan để dán ở văn phòng nhằm nhắc nhở 20 nhân sự về quy tắc "Bàn làm việc sạch - Màn hình sạch".

KHÂU 3: CHECK (Giám sát & Đánh giá nội bộ) - *Chiếm 10% tổng số điểm*

- **Đầu mục 3.1: Xây dựng Audit Checklist:** Lập một bảng câu hỏi kiểm toán nội bộ dựa trên chính văn bản quy định đã viết ở Khâu DO để tiến hành kiểm tra đột xuất.
- **Đầu mục 3.2: Giả định tình huống lỗi (Audit Findings):** Giả định sau 3 tháng vận hành, đội tư vấn tiến hành đánh giá nội bộ và phát hiện ra **02 điểm không tuân thủ**.
    - *Ví dụ tình huống lỗi:* Phát hiện 01 lập trình viên cấp cao tắt tính năng mã hóa ổ cứng vì kêu máy chạy chậm; hoặc mật khẩu tài khoản quản trị GitHub của công ty bị nhân viên kinh doanh chép vào file Notepad công khai trên màn hình desktop.

KHÂU 4: ACT (Khắc phục & Cải tiến liên tục) - *Chiếm 10% tổng số điểm*

Từ 02 lỗi giả định ở Khâu CHECK, nhóm phải đưa ra giải pháp xử lý triệt để:

- **Đầu mục 4.1: Khắc phục tức thời (Correction):** Đưa ra hành động xử lý ngay lập tức để cô lập nguy cơ (Xóa file notepad, bắt bật lại mã hóa).
- **Đầu mục 4.2: Hành động khắc phục tận gốc (Corrective Action):** Phân tích nguyên nhân sâu xa (Root cause analysis). Tại sao nhân viên lại làm vậy? Do chính sách quá khó hiểu hay do thiếu công cụ quản lý tập trung?
- **Đầu mục 4.3: Đề xuất cải tiến:** Đề xuất một giải pháp thay đổi quy trình hoặc công cụ kỹ thuật để lỗi này không bao giờ lặp lại (Ví dụ: Đề xuất áp dụng giải pháp Quản lý thiết bị di động - MDM bản miễn phí/giá rẻ để tự động đẩy chính sách xuống máy nhân viên, không cho phép họ tự ý tắt mã hóa).

3. Kết quả đầu ra (Deliverables)

1. **Quyển Báo cáo Bài tập lớn (PDF):** Nội dung trình bày sạch sẽ, khoa học, có sơ đồ biểu bảng rõ ràng. Cấu trúc nội dung bắt buộc phải chia thành 4 phần tương ứng với 4 khâu: **PLAN, DO, CHECK, ACT** với đầy đủ các đầu mục công việc đã nêu ở Mục 2.
2. **Vàn văn Bản Chính sách BYOD độc lập (PDF):** Bản dự thảo quy định bảo mật thiết bị cá nhân dài từ 2-3 trang, có đầy đủ các mục: Mục đích, Phạm vi áp dụng, Quy định chi tiết, và Chế tài xử lý khi vi phạm.
3. **Tệp tài liệu hướng dẫn kỹ thuật Baseline (File PDF/Slide):** Tập hợp các ảnh chụp màn hình (Screenshot) từng bước thiết lập cấu hình an toàn trên máy tính cá nhân thực tế của các thành viên trong nhóm làm mẫu.
4. **Sản phẩm truyền thông Nhận thức (File Ảnh/PDF/Canva link):** 01 Infographic hoặc Poster dán tường định dạng số, thiết kế trực quan, dễ hiểu về quy tắc "Bàn làm việc sạch - Màn hình sạch".
5. **Biên bản Đánh giá & Khắc phục:** Bảng Checklist kiểm toán nội bộ đã điền kết quả kiểm tra giả định, kèm theo văn bản tường trình xử lý 02 lỗi không tuân thủ và giải pháp ACT cải tiến hệ thống./.

Đề tài 2: Áp dụng chu trình TCVN ISO/IEC 27001:2019 để đánh giá hiện trạng, thiết lập hệ thống bảo vệ an toàn thông tin cho Phòng máy tính thực hành và thi tập trung

1. Bối cảnh bài toán (Scenario)

Phòng máy tính thực hành của Khoa mạng/ATTT gồm 40 máy trạm dành cho sinh viên và 01 máy bàn dành cho Giảng viên/Hội đồng coi thi. Các máy kết nối mạng LAN nội bộ và đi Internet qua một Router trung tâm. Phòng máy này vừa dùng để học tập các môn kỹ thuật, vừa là **Phòng thi chứng chỉ/Thi cuối kỳ tập trung** của nhà trường.

Đặc thù của phòng Lab này là: Đối tượng sử dụng thay đổi liên tục theo ca học (3 tiếng/ca); sinh viên có trình độ kỹ thuật cao (dân CNTT/An ninh mạng) thường xuyên tìm cách "thử nghiệm" hệ thống; dữ liệu đề thi và bài làm của sinh viên yêu cầu tính toàn vẹn và bí mật tuyệt đối trong thời gian diễn ra kỳ thi. Hiện tại hệ thống đang vận hành thủ công, không có cơ chế tự động xóa dữ liệu sau ca học và chưa có quy trình niêm phong dữ liệu thi bài bản.

2. Nhiệm vụ của nhóm sinh viên (Cấu trúc theo chu trình PDCA)

KHÂU 1: PLAN (Lập kế hoạch & Thiết kế hệ thống) - *Chiếm 60% tổng số điểm*

- **Đầu mục 1.1: Asset Inventory:** Lập bảng danh mục tối thiểu **10 tài sản**. Phải bóc tách rõ: Tài sản máy trạm sinh viên (Cấu hình HĐH, quyền truy cập); Tài sản dữ liệu thi (Đề thi chưa công bố, bài làm của thí sinh, log giám sát thi); Tài sản hạ tầng (Kênh truyền mạng LAN phục vụ thi, Router phát Wi-Fi phòng thi).
- **Đầu mục 1.2: Risk Register & Gap Analysis (Đánh giá rủi ro đặc thù phòng thi):** Xác định và phân tích ít nhất **12 nguy cơ** thực tế, tập trung vào:
    - *Gian lận và lộ lọt:* Thí sinh ca sau lấy được bài làm/phao thi của ca trước; Thí sinh tìm cách bắt Wi-Fi ngoài hoặc chia sẻ bài qua mạng LAN; Đề thi bị rò rỉ từ máy giảng viên trước giờ G.
    - *Sự cố vận hành:* Máy trạm bị nhiễm mã độc độc hại từ ca học trước làm sập máy đúng giờ thi của ca sau; Mất điện đột ngột hoặc mất kết nối về máy chủ nộp bài làm mất bài thi của thí sinh.
- **Đầu mục 1.3: Statement of Applicability (SoA) & Risk Treatment Plan (RTP):** Đối chiếu Phụ lục A ISO 27001 (Đặc biệt là A.12.4 - Ghi nhật ký và giám sát; A.12.1 - Quy trình vận hành và trách nhiệm; A.13.1 - Kiểm soát an toàn mạng). Lập kế hoạch xử lý (RTP) bằng công cụ cụ thể (Ưu tiên giải pháp miễn phí/có sẵn).

KHÂU 2: DO (Thiết kế giải pháp triển khai hàng loạt) - *Chiếm 20% tổng số điểm*

Nhóm phải tạo ra các sản phẩm thể hiện tư duy quản lý hệ thống trên quy mô lớn:

- **Đầu mục 2.1: Dự thảo Văn bản Quy trình vận hành phòng thi (Standard Operating Procedure - SOP):** Viết quy trình 3 trang quy định rõ: Cán bộ kỹ thuật phải chuẩn bị máy như thế nào trước giờ thi; Quy trình bàn giao đề thi; Quy trình niêm phong và thu bài làm (Tương ứng với kiểm soát A.12.1.1).
- **Đầu mục 2.2: Demo Kỹ thuật Cấu hình Master Image (Hardening):** Chụp ảnh minh họa các bước thiết lập một **"Máy trạm chuẩn (Master Image)"** an toàn. Sinh viên phải chỉ ra cách: Tạo script tự động xóa sạch dữ liệu trong thư mục Temp/Download khi khởi động lại máy; Cấu hình Local Group Policy để khóa hoàn

toàn quyền vào Control Panel, Registry Editor và chặn không cho sinh viên tự ý đổi IP của máy nhằm qua mặt hệ thống chấm thi.

- **Đầu mục 2.3: Poster quy chế phòng thi (Awareness):** Thiết kế 01 Infographic dán tại cửa phòng thi tóm tắt các hành vi kỹ thuật bị cấm đối với thí sinh.

KHÂU 3: CHECK (Giám sát & Đánh giá nội bộ) - *Chiếm 10% tổng số điểm*

- **Đầu mục 3.1: Xây dựng Audit Checklist:** Lập bảng câu hỏi kiểm tra kỹ thuật và quy trình ngay trước và sau một ca thi cụ thể.
- **Đầu mục 3.2: Giả định tình huống lỗi mùa thi (Audit Findings):** Giả định trong kỳ thi cuối kỳ, đội kiểm toán phát hiện ra **02 điểm lỗi nghiêm trọng**:
    - *Lỗi 1 (Kỹ thuật):* Một số máy trạm có lỗi không tự xóa lịch sử duyệt web, thí sinh ca sau vẫn vào được tài khoản thi trực tuyến của thí sinh ca trước.
    - *Lỗi 2 (Quy trình):* Giảng viên coi thi tự ý cắm USB cá nhân vào máy giảng viên để copy bài làm của sinh viên mang về nhà chấm, không tuân thủ quy trình bàn giao lưu trữ tập trung của Khoa.

KHÂU 4: ACT (Khắc phục & Cải tiến hệ thống) - *Chiếm 10% tổng số điểm*

Từ 02 lỗi giả định ở Khâu CHECK, nhóm đưa ra giải pháp khép kín chu trình:

- **Đầu mục 4.1: Khắc phục tức thời (Correction):** Đăng xuất từ xa toàn bộ tài khoản, thu hồi và định dạng (format) lại USB của giảng viên, chuyển bài thi vào vùng lưu trữ an toàn.
- **Đầu mục 4.2: Hành động khắc phục tận gốc (Corrective Action):** Tìm nguyên nhân tại sao script xóa dữ liệu bị lỗi (do xung đột quyền của tài khoản User)? Tại sao giảng viên lại dùng USB (do hệ thống nộp bài trực tuyến của Khoa bị chậm/khó dùng)?
- **Đầu mục 4.3: Đề xuất cải tiến:** Đề xuất giải pháp công nghệ triệt để. (Ví dụ: Thay vì dùng kịch bản script thủ công trên từng máy, đề xuất Khoa áp dụng công nghệ **VDI** – mỗi ca thi hệ thống sẽ tự động cấp một máy ảo mới tinh từ máy chủ trung tâm, sinh viên tắt máy là máy ảo tự hủy; thiết lập cổng nộp bài nội bộ riêng cho giảng viên).

3. Kết quả đầu ra (Deliverables)

Mỗi nhóm sinh viên phải nộp đầy đủ bộ sản phẩm bàn giao sau 1.5 tháng:

1. **Quyển Báo cáo Bài tập lớn (File PDF):** Gồm 4 phần tương ứng với 4 khâu: **PLAN, DO, CHECK, ACT** với các số liệu và phân tích đặc thù cho phòng Lab thi tập trung.
2. **Văn bản Quy trình Vận hành Phòng thi độc lập - SOP (File Word):** Bản hướng dẫn từng bước dành cho kỹ thuật viên và giảng viên coi thi.
3. **Tệp hướng dẫn kỹ thuật đóng gói Master Image (File PDF/Slide):** Tập hợp ảnh chụp cấu hình Group Policy, kịch bản xóa file tự động được thực hiện thành công trên máy mẫu của nhóm.
4. **Sản phẩm truyền thông Nhận thức (File Ảnh/PDF):** Poster quy chế bảo mật phòng thi dành cho thí sinh.
5. **Biên bản Kiểm toán và Phương án Cải tiến VDI/Quy trình (Nằm trong báo cáo):** Phân tích 02 lỗi mùa thi và đề xuất kiến trúc cải tiến công nghệ quản lý tập trung./.

Đề tài 3: Áp dụng TCVN ISO/IEC 27001:2019 để thiết kế, triển khai và cải tiến Chương trình Đào tạo Nhận thức An toàn thông tin cho Khối Văn phòng Trường học

1. Bối cảnh bài toán (Scenario)

Khối văn phòng của một Trường Đại học bao gồm **10 nhân sự** thuộc 2 phòng ban chính: **Phòng Kế toán** và **Phòng Quản lý đào tạo/Tuyển sinh**. Do đặc thù công việc, nhóm này thường xuyên xử lý các dữ liệu nhạy cảm: thông tin định danh học sinh/sinh viên, bảng điểm, thông tin tài chính và học phí.

Hiện tại, nhóm nhân sự này đang có những thói quen vận hành tiềm ẩn rủi ro rất cao:

- Thường xuyên nhận và mở các tệp đính kèm từ các địa chỉ email lạ gửi đến.
- Có thói quen chép mật khẩu hệ thống phần mềm quản lý ra giấy dán tường hoặc dán ngay dưới bàn phím.
- Sử dụng máy tính làm việc để tải và cài đặt các phần mềm crack phục vụ công việc hành chính.
- Rời bàn làm việc đi họp hoặc đi ăn trưa nhưng không khóa màn hình máy tính trong khi văn phòng thường xuyên có khách ra vào.

Ban Giám hiệu yêu cầu phải xây dựng một chiến dịch nâng cao nhận thức để thay đổi hành vi của khối văn phòng này.

2. Nhiệm vụ của nhóm sinh viên (Cấu trúc theo chu trình PDCA)

Sinh viên đóng vai một **Đội chuyên gia Đào tạo nhận thức ATTT nội bộ**, có nhiệm vụ thiết kế và vận hành chu trình nâng cao nhận thức con người trong vòng 1.5 tháng. Nội dung thực hiện bắt buộc phải đi qua 4 khâu:

KHÂU 1: PLAN (Lập kế hoạch & Thiết kế chương trình) - *Chiếm 60% tổng số điểm*

- **Đầu mục 1.1: Human Asset & Data Inventory (Kiểm kê nhân sự và Dữ liệu tiếp cận):** Lập bảng phân loại 10 nhân sự theo 2 phòng ban. Xác định rõ loại dữ liệu nhạy cảm mà từng phòng đang nắm giữ và mức độ tổn thất nếu họ bị lừa gạt.
- **Đầu mục 1.2: Risk Register (Phân tích hành vi nguy hiểm):** Xác định và phân tích ít nhất **08 nguy cơ** bắt nguồn hoàn toàn từ thói quen sai lầm của con người trong bối cảnh trên. Phải mô tả rõ kịch bản tấn công dựa trên tâm lý con người, tập trung vào: Tấn công giả mạo (Phishing email), Rò rỉ vật lý (nhìn trộm mật khẩu/màn hình), và Xâm nhập từ mã độc ẩn trong phần mềm bẻ khóa.
- **Đầu mục 1.3: SoA & Awareness Strategy (Lựa chọn kiểm soát & Khung bài học):** Đối chiếu Phụ lục A ISO 27001 (Tập trung vào các điều khoản: A.7.2.2 - Đào tạo và nâng cao nhận thức về ATTT; A.11.2.9 - Chính sách bàn làm việc sạch và màn hình sạch). Thiết kế khung nội dung bài học: *Họ sẽ được học những gì? Thời lượng bao lâu? Học bằng hình thức nào?*

KHÂU 2: DO (Sản xuất học liệu & Truyền thông mẫu) - *Chiếm 20% tổng số điểm*

Nhóm trực tiếp đóng vai "Đội ngũ sản xuất nội dung" để tạo ra các sản phẩm truyền thông bằng ngôn ngữ bình dân, trực quan, không dùng từ ngữ kỹ thuật đánh đố:

- **Đầu mục 2.1: Bộ văn bản "Cẩm nang quy tắc ứng xử an toàn (Security Guidelines)"**: Viết một tài liệu ngắn (khoảng 2 trang) chỉ rõ những điều **NÊN** và **KHÔNG NÊN làm** dành riêng cho dân văn phòng (Cách check mail giả mạo, quy tắc đặt mật khẩu, quy trình xử lý khi nghi ngờ máy bị nhiễm độc).
- **Đầu mục 2.2: Demo Kỹ thuật Trực quan cho bài học:** Tạo một tệp tài liệu hướng dẫn (PDF/Slide) bằng hình ảnh thực tế để dạy người văn phòng. Sinh viên tự chụp ảnh/thiết kế minh họa: Cách phân biệt một email thật và một email Phishing; Cách cấu hình máy tính tự động khóa màn hình sau 3 phút.
- **Đầu mục 2.3: Ấn phẩm truyền thông trực quan:** Thiết kế **01 Infographic hoặc Poster** tổng hợp lồng ghép khéo léo cả 2 thông điệp: "Cảnh giác Email lừa đảo" và "Quy tắc Bàn làm việc sạch - Màn hình sạch".

KHÂU 3: CHECK (Diễn tập giả định & Đánh giá hành vi) - *Chiếm 10% tổng số điểm*

- **Đầu mục 3.1: Thiết kế Kịch bản Diễn tập:** Thiết kế kịch bản kiểm tra ngầm để đo lường hành vi sau đào tạo (Ví dụ: Thiết kế mẫu 01 email giả mạo thông báo điều chỉnh quy chế thưởng/phạt của nhà trường để gửi đồng loạt cho 15 nhân sự nhằm đếm xem có bao nhiêu người sập bẫy click vào link).
- **Đầu mục 3.2: Giả định tình huống lỗi sau đào tạo (Audit Findings):** Giả định sau chiến dịch, đội kiểm tra phát hiện ra **02 điểm lỗi về con người**:
    - *Lỗi 1 (Hành vi kỹ thuật):* Qua hệ thống diễn tập, có một số nhân viên phòng Tuyển sinh vẫn bấm vào đường link độc hại và điền thông tin tài khoản nội bộ.
    - *Lỗi 2 (Tuân thủ vật lý):* Đi kiểm tra văn phòng lúc nghỉ trưa, phát hiện máy tính của phòng Kế toán vẫn mở màn hình hiển thị bảng dữ liệu tài chính, nhân sự đã rời khỏi phòng.

KHÂU 4: ACT (Xử lý sự cố con người & Cải tiến chiến dịch) - *Chiếm 10% tổng số điểm*

Từ 02 lỗi giả định ở Khâu CHECK, nhóm đưa ra giải pháp xử lý và cải tiến để khép kín chu trình PDCA:

- **Đầu mục 4.1: Khắc phục tức thời (Correction):** Đổi mật khẩu của nhân sự sập bẫy email, kích hoạt khóa màn hình từ xa, nhắc nhở trực tiếp cá nhân vi phạm.
- **Đầu mục 4.2: Phân tích nguyên nhân (Root Cause Analysis):** Phân tích sâu nguyên nhân tại sao họ vẫn vi phạm dù đã được học (Do áp lực công việc quá bận nên quên quy trình, hay do email bẫy đánh trúng tâm lý tò mò?).
- **Đầu mục 4.3: Đề xuất cải tiến giải pháp:** Đề xuất giải pháp kết hợp kỹ thuật công nghệ để bù đắp cho lỗ hổng con người (Ví dụ: Ép buộc khóa màn hình bằng mã lệnh hệ thống sau 2 phút; cấu hình bộ lọc mail để chặn email lạ; đề xuất đưa tuân thủ ATTT vào khung xét thi đua khen thưởng).

3. Kết quả đầu ra (Deliverables)

1. **Quyển Báo cáo Bài tập lớn (File PDF):** Gồm 4 phần tương ứng với 4 khâu: **PLAN, DO, CHECK, ACT** tập trung vào mảng An toàn thông tin nguồn nhân lực cho khối văn phòng với các số liệu tối ưu (15 nhân sự, 07 rủi ro).

2. **Văn bản Cẩm nang Quy tắc Ứng xử An toàn cho Dân văn phòng (File PDF):** Tài liệu hướng dẫn ngắn gọn, dài khoảng 2 trang, ngôn từ bình dân, dễ hiểu.
3. **Bộ Slide Bài giảng Nhận thức ATTT (File PPTX/PDF):** Slide đào tạo trực quan có hình ảnh minh họa thực tế (đã chuẩn bị ở mục 2.2).
4. **Sản phẩm truyền thông Nhận thức (File Ảnh/Canva link): 01 Poster/Infographic** tổng hợp được thiết kế bắt mắt, thông điệp ngắn gọn, dán văn phòng. *(Cắt giảm 1 file thiết kế so với bản cũ)*
5. **Kịch bản Diễn tập và Phương án Cải tiến (Nằm trong báo cáo):** Bản mô tả nội dung email bẫy giả định, phân tích lỗi phát hiện và đề xuất các biện pháp cải tiến công nghệ kết hợp chính sách.

Đề tài 4: Thiết lập Hồ sơ Đề xuất Cấp độ và Phương án Bảo đảm An toàn Thông tin theo TCVN 11930:2017 cho Hệ thống Đăng ký Tín chỉ Đại học (Mô phỏng Cấp độ 2)

1. Bối cảnh bài toán (Scenario)

Trường Đại học X có quy mô **15.000 sinh viên** đang vận hành "Hệ thống Quản lý Đào tạo và Đăng ký Tín chỉ" trực tuyến. Hệ thống được cấu trúc gồm hai thành phần chính: **01 Web Portal giao tiếp trực tuyến với sinh viên** đặt ở vùng mạng mở, **01 Máy chủ cơ sở dữ liệu lõi (DB Server)** lưu trữ điểm số, thông tin học phí được đặt ở vùng mạng nội bộ cách ly.

Hệ thống vận hành theo chu kỳ: Ngày thường lưu lượng truy cập rất thấp, nhưng vào mùa đăng ký tín chỉ, hệ thống phải chịu tải đồng thời từ hàng ngàn sinh viên, dẫn đến nguy cơ nghẽn mạng hoặc sập hệ thống. Ngoài ra, hệ thống đối mặt với nguy cơ bị tấn công thay đổi điểm số hoặc tấn công từ chối dịch vụ (DDoS). Trường cần xây dựng một bộ Hồ sơ đề xuất cấp độ và Phương án bảo đảm an toàn thông tin theo TCVN 11930:2017 để trình phê duyệt.

2. Nhiệm vụ của nhóm sinh viên (Cấu trúc theo Quy trình Thiết lập & Thực thi Cấp độ)

Sinh viên đóng vai một **Đội chuyên gia An toàn thông tin nội bộ**, triển khai báo cáo qua 4 khâu chuyên biệt của TCVN 11930 nhưng tập trung vào các lát cắt cốt lõi:

KHÂU 1: ĐỊNH DANH VÀ THUYẾT MINH CẤP ĐỘ - *Chiếm 60% tổng số điểm*

- **Đầu mục 1.1: Khảo sát và Xác định Biên giới Hệ thống (System Boundary):** Lập bảng kê rõ các thành phần phần cứng, phần mềm và dữ liệu của 2 thành phần (Web Portal và Database). Vẽ sơ đồ kiến trúc logic hiện tại của hệ thống.
- **Đầu mục 1.2: Thuyết minh Xác định Cấp độ An toàn (Classification):** Áp dụng các tiêu chí định tính và định lượng của TCVN 11930 để lập luận tại sao hệ thống này thuộc **Cấp độ 2**. Sinh viên phân tích thiệt hại trên 2 khía cạnh: Thiệt hại đối với Nhà trường (vận hành, uy tín) và Thiệt hại đối với sinh viên (quyền lợi học tập, lộ lọt thông tin cá nhân).
- **Đầu mục 1.3: Trích xuất Baseline Yêu cầu tối thiểu:** Tra cứu và lập bảng danh mục các yêu cầu bảo đảm an toàn bắt buộc cho Hệ thống Cấp độ 2 trong TCVN 11930:2017. *Chỉ trích xuất các điều khoản liên quan trực tiếp đến: An toàn mạng, Kiểm soát truy cập và Quản lý vận hành.*

KHÂU 2: THIẾT KẾ PHƯƠNG ÁN PHÒNG THỦ - *Chiếm 20% tổng số điểm*

Nhóm trực tiếp thiết kế giải pháp kỹ thuật mạng và quy trình để đáp ứng yêu cầu tối thiểu đã trích xuất:

- **Đầu mục 2.1: Quy chế Quản lý Vận hành Hệ thống theo Luật:** Soạn thảo văn bản "Quy chế quản lý, vận hành và an toàn thông tin cho Hệ thống Tín chỉ" (dài 2 trang). Văn bản phải cụ thể hóa quy định về cấp phát/thu hồi tài khoản và lịch trình sao lưu (backup) dữ liệu điểm.
- **Đầu mục 2.2: Thiết kế Sơ đồ Phân vùng mạng An toàn (Network Segmentation):** Thiết kế lại sơ đồ mạng áp dụng yêu cầu "An toàn mạng" của TCVN 11930. Sinh viên phải phân chia rõ ràng hệ thống thành 3 phân vùng logic (VLAN) và thiết lập luật tường lửa (Firewall Rules) giữa các vùng: Vùng bên ngoài (Internet), Vùng trung gian (DMZ - chứa Web Portal), và Vùng an toàn (Inside LAN - chứa Database Server).

KHÂU 3: KIỂM TRA ĐÁNH GIÁ TUÂN THỦ - *Chiếm 10% tổng số điểm*

- **Đầu mục 3.1: Xây dựng Biên bản Đánh giá Tuân thủ (Compliance Checklist):** Thiết kế một bảng checklist ngắn gọn (khoảng 10-12 câu hỏi) dùng để rà soát hệ thống. Các câu hỏi phải dịch từ ngôn ngữ tiêu chuẩn thành hành động kỹ thuật thực tế (Ví dụ: "Luật tường lửa đã chặn cổng kết nối trực tiếp từ Internet vào Database chưa?").
- **Đầu mục 3.2: Giả định điểm hở kỹ thuật (Findings):** Giả định trong quá trình rà soát, nhóm phát hiện ra **02 điểm lỗi vi phạm** tiêu chuẩn Cấp độ 2:
    - *Lỗi 1 (Kỹ thuật mạng):* Phân vùng Database và phân vùng Web Portal đang thông nhau hoàn toàn, chưa có luật chặn kiểm soát luồng dữ liệu trực tiếp.
    - *Lỗi 2 (Quản lý vận hành):* Chưa có kịch bản và quy trình ứng phó khẩn cấp khi hệ thống bị tấn công DDoS nghẽn mạng đúng giờ đăng ký tín chỉ.

KHÂU 4: PHƯƠNG ÁN KHẮC PHỤC VÀ CẢI TIẾN - *Chiếm 10% tổng số điểm*

Từ 02 lỗi giả định ở Khâu 3, nhóm đưa ra giải pháp sửa lỗi để hoàn thiện hồ sơ:

- **Đầu mục 4.1: Khắc phục kỹ thuật tức thời:** Viết kịch bản cấu hình luật Firewall chặn ngay luồng đi trực tiếp từ vùng ngoài vào vùng Database (ép buộc mọi luồng dữ liệu truy vấn phải đi qua ứng dụng trung gian).
- **Đầu mục 4.2: Xây dựng Kịch bản Ứng phó sự cố khẩn cấp (Incident Response Plan):** Thiết kế quy trình phối hợp 4 bước khi bị tấn công DDoS (Phát hiện -> Cô lập/Định tuyến lại luồng mạng -> Kích hoạt trang thông báo tạm thời -> Khôi phục).

3. Kết quả đầu ra (Deliverables)

1. **Quyển Báo cáo Bài tập lớn (File PDF):** Gồm 4 phần tương ứng với 4 khâu chuyên biệt của TCVN 11930 nêu trên, dung lượng tinh gọn (khoảng 15 trang).
2. **Bản vẽ Kiến trúc Mạng An toàn (File Ảnh/PDF từ Visio/Draw.io):** Sơ đồ phân vùng mạng (Internet, DMZ, Inside LAN) rõ ràng, kèm theo bảng ma trận luật tường lửa (Firewall Rules Matrix) cho phép hoặc cấm các luồng dữ liệu.
3. **Văn bản Quy chế An toàn Thông tin Hệ thống Tín chỉ (File Word):** Bản quy chế dài 2 trang phân định rõ quyền hạn quản trị hệ thống, quy định đặt mật khẩu máy chủ và lịch trình backup dữ liệu.
4. **Biên bản rà soát lỗi và Kịch bản ứng phó DDoS (Nằm trong báo cáo):** Bảng checklist đánh giá tuân thủ, biên bản ghi nhận 2 lỗi hệ thống và tài liệu kịch bản xử lý khẩn cấp khi bị DDoS nghẽn mạng./.

Đề tài 5: Áp dụng TCVN 11930:2017 để Thiết kế Kiến trúc Mạng Phân vùng An toàn và Quy trình Vận hành cho Chuỗi Quán Cà phê Dịch vụ (Mô phỏng Cấp độ 1)

1. Bối cảnh bài toán (Scenario)

Một chuỗi quán cà phê có 3 chi nhánh đang vận hành một hệ thống công nghệ tại mỗi cửa hàng bao gồm: 02 Máy tính tiền và in hóa đơn của thu ngân (POS), 04 IP Camera giám sát an ninh (truyền hình ảnh liên tục về máy chủ đám mây của đơn vị cung cấp camera), và 01 Hệ thống Wi-Fi miễn phí phục vụ trung bình 100 khách hàng truy cập đồng thời mỗi ngày.

Hiện tại, do lắp đặt tự phát, tất cả thiết bị này đều cắm chung vào 01 Router Wi-Fi mặc định do nhà mạng cung cấp. Hệ thống đang đối mặt với những nguy cơ nhãn tiền: Khách hàng sử dụng các ứng dụng quét mạng trên điện thoại có thể nhìn thấy và truy cập vào trang quản trị của máy POS/Camera; mã độc từ máy tính của khách có thể lây lan sang máy POS gây thất thoát dữ liệu doanh thu; hoặc băng thông mạng bị nghẽn do khách xem video chất lượng cao, khiến máy POS không thể quẹt thẻ thanh toán hoặc đồng bộ dữ liệu về trung tâm.

2. Nhiệm vụ của nhóm sinh viên (Cấu trúc theo Quy trình Phân tích & Phòng thủ Mạng)

Sinh viên đóng vai **Đội kỹ sư An ninh mạng nội bộ** của chuỗi cửa hàng, có nhiệm vụ thiết kế lại kiến trúc mạng và ban hành quy chế vận hành an toàn trong vòng 1.5 tháng qua 4 khâu:

KHÂU 1: PHÂN LOẠI TÀI SẢN, XÁC ĐỊNH NGUY CƠ - *Chiếm 60% tổng số điểm*

- **Đầu mục 1.1: Khảo sát và Kiểm kê Tài sản Hạ tầng (Asset Inventory):** Lập bảng danh mục tối thiểu **08 tài sản** công nghệ có tại một chi nhánh quán cà phê (bóc tách rõ các thiết bị phần cứng, các dòng dữ liệu truyền nhận và con người vận hành). Xác định rõ mức độ ưu tiên về tính Sẵn sàng và tính Bảo mật của từng tài sản.
- **Đầu mục 1.2: Thuyết minh Cấp độ và Phân tích Nguy cơ (Risk Register):** * Lập luận ngắn gọn dựa trên TCVN 11930 để định danh hệ thống thuộc **Cấp độ 1**.

Hãy vẽ luôn bảng cho từng đầu mục khâu 1 nhá để còn biết tính điểm từng khâu

  - Xác định và phân tích ít nhất **06 nguy cơ** mất an toàn đặc thù do việc "dùng chung mạng mạng cục bộ", tập trung vào: Khách hàng xem trộm IP Camera; Khách hàng dò quét cấu hình máy POS; Nghẽn băng thông thanh toán do nghẽn mạng công cộng; Nhân viên tự ý dùng máy POS vào việc riêng.
- **Đầu mục 1.3: Trích xuất Baseline Yêu cầu Kỹ thuật mạng:** Tra cứu TCVN 11930:2017 để trích xuất các điều khoản bắt buộc về "An toàn mạng" và "Kiểm soát truy cập" đối với Hệ thống Cấp độ 1 (Tập trung vào yêu cầu phân tách các dòng lưu lượng mạng có mục đích khác nhau).

KHÂU 2: KIẾN TRÚC MẠNG, CHÍNH SÁCH BẢO VỆ - *Chiếm 20% tổng số điểm*

Nhóm trực tiếp đóng vai trò kỹ sư hệ thống để thiết kế giải pháp cô lập rủi ro bằng tư duy logic (không yêu cầu cấu hình thiết bị thật hoặc gõ lệnh):

- **Đầu mục 2.1: Thiết kế Sơ đồ Phân vùng mạng logic:** Vẽ lại sơ đồ kiến trúc mạng an toàn cho một chi nhánh bằng công cụ trực quan (Draw.io/Visio), phân vùng mạng logic thành 3 vùng biệt lập rõ ràng: **Vùng Wi-Fi Khách (Guest Zone)**, **Vùng Camera Giám sát (CCTV Zone)**, và **Vùng Nghiệp vụ Thanh toán (POS Zone)**.
- **Đầu mục 2.2: Thiết lập Bảng Nguyên tắc Luồng Dữ liệu:** Thiết lập một bảng ma trận bằng ngôn ngữ logic thông thường để định nghĩa các luồng kết nối hợp lệ và bị cấm giữa các vùng nhằm đáp ứng tiêu chuẩn.

    - *Ví dụ:* "Mạng Wi-Fi Khách $\rightarrow$ Máy POS: BỊ CẤM hoàn toàn để tránh rà quét; Máy POS $\rightarrow$ Internet: ĐƯỢC PHÉP (chỉ để đồng bộ về máy chủ trung tâm)".

- **Đầu mục 2.3: Dự thảo Quy chế Sử dụng Thiết bị tại Cửa hàng:** Soạn thảo văn bản quy định dài 2 trang dành cho Quản lý cửa hàng và Thu ngân về việc bảo vệ thiết bị (Ví dụ cấm dùng máy POS vào việc riêng, quy định vị trí đặt Router để tránh bị khách rút dây/reset phần cứng vật lý).

KHÂU 3: KIỂM TRA ĐÁNH GIÁ SỰ CỐ GIẢ ĐỊNH - *Chiếm 10% tổng số điểm*

- **Đầu mục 3.1: Xây dựng Checklist Hậu kiểm Kỹ thuật mạng:** Lập một bảng checklist ngắn (10 câu hỏi) bằng hành động thực tế dùng để đi rà soát cấu hình mạng tại các quán (Ví dụ: "Tên Wi-Fi của khách và của nội bộ đã tách riêng chưa?", "Mật khẩu quản trị Router có còn để mặc định của nhà mạng không?").
- **Đầu mục 3.2: Giả định tình huống hở mạng thực tế (Audit Findings):** Giả định trong một buổi kiểm tra đột xuất tại chi nhánh 2, đội kỹ thuật phát hiện ra **02 điểm vi phạm an toàn**:
    - *Lỗi 1 (Kỹ thuật):* Thiết bị Router Wi-Fi mới bị lỗi cấu hình sau khi reset, dẫn đến việc Vùng Wi-Fi Khách lại thông sang Vùng Camera, khiến khách hàng có thể dò ra địa chỉ IP và xem trộm dữ liệu của 4 Camera.
    - *Lỗi 2 (Quy trình con người):* Nhân viên ca tối đã tự ý chia sẻ mật khẩu mạng Wi-Fi nội bộ (mạng dùng để đẩy dữ liệu doanh thu) cho một vài khách quen để họ chơi game cho mượt.

KHÂU 4: PHƯƠNG ÁN KHẮC PHỤC VÀ TỐI ƯU HẠ TẦNG (ACT) - *Chiếm 10% tổng số điểm*

Từ 2 lỗi hệ thống phát hiện ở Khâu 3, nhóm đưa ra phương án xử lý triệt để nhằm hoàn thiện chu trình:

- **Đầu mục 4.1: Sửa lỗi kỹ thuật tức thời (Correction):** Đưa ra giải pháp logic để đóng/chặn ngay luồng giao tiếp giữa 2 mạng VLAN của Khách và Camera; Thực hiện đổi ngay mật khẩu Wi-Fi nội bộ của cửa hàng.
- **Đầu mục 4.2: Hành động xử lý tận gốc (Corrective Action):** Thay đổi phương thức xác thực mạng để tránh nhân viên tự ý chia sẻ mật khẩu (Ví dụ: Ẩn tên Wi-Fi (SSID) mạng nội bộ hoặc cấu hình giới hạn chỉ những địa chỉ MAC của máy POS mới được phép kết nối).
- **Đầu mục 4.3: Đề xuất cải tiến công nghệ quản lý chuỗi:** Đề xuất giải pháp quản lý tập trung từ xa ở mức độ tổng quan kiến trúc (Ví dụ: Đề xuất chuỗi áp dụng giải pháp **SD-WAN** hoặc thiết bị **Cloud-Managed Router** để kỹ sư tổng tại trụ sở chính có thể giám sát, tự động đồng bộ cấu hình cô lập luồng mạng của cả 3 quán cùng lúc qua màn hình Dashboard mà không cần cấu hình thủ công tại từng quán).

3. Kết quả đầu ra (Deliverables)

1. **Quyển Báo cáo Bài tập lớn (File PDF):** Quyển báo cáo dung lượng khoảng 12-15 trang, cấu trúc theo đúng 4 khâu: **PLAN, DO, CHECK, ACT** tập trung vào bài toán an toàn mạng phân vùng cho mô hình chuỗi dịch vụ.

2. **Bản vẽ Sơ đồ Kiến trúc Mạng Phân vùng (File Ảnh/PDF từ phần mềm Draw.io/Visio):** Sơ đồ trực quan thể hiện rõ cách chia 3 vùng mạng logic tại quán và hướng mũi tên đi của các luồng dữ liệu hợp lệ.
3. **Bảng Ma trận Nguyên tắc Luồng Dữ liệu (Nằm trong báo cáo):** Bảng định nghĩa bằng ngôn ngữ logic các hướng kết nối được phép và bị cấm giữa các vùng, thể hiện rõ việc cô lập vùng nhạy cảm (POS, Camera) khỏi vùng nguy hiểm (Wi-Fi Khách).
4. **Văn bản Quy chế An toàn Thiết bị tại Cửa hàng (File PDF):** Bản nội quy hướng dẫn nhân viên quán bảo vệ máy tính tiền và thiết bị mạng vật lý.
5. **Biên bản Kiểm toán và Đề xuất giải pháp (Nằm trong báo cáo):** Bảng checklist đánh giá tuân thủ mạng, biên bản xử lý 2 sự cố hở mạng logic và tài liệu thuyết minh giải pháp quản lý hạ tầng tập trung từ xa (SD-WAN/Cloud-managed) ở mức độ tổng quan kiến trúc.